

ACTIVE DIRECTORY TEMELLERİ

[Kaynak](#)

İÇERİK

1. Windows Domains (Windows Domain Yapıları)
2. Active Directory Domain Service (AD DS)
3. Active Directory'de Kullanıcı ve OU Yönetimi
4. Active Directory'de Bilgisayar Yönetimi ve Nesne Organizasyonu
5. Group Policy Objects (GPO) - Grup Politikaları
6. Authentication Methods (Kimlik Doğrulama Yöntemleri)
7. Trees, Forests and Trusts (Ağaçlar, Ormanlar ve Güven İlişkileri)

Windows Domains (Windows Domain Yapıları)

Büyük ölçekli ağları yönetmenin temel taşı olan **Windows Domain** kavramını ve bu yapının neden bir zorunluluk olduğunu en ince ayrıntısına kadar inceleyelim. Bu notlar, bir ağın neden "Workgroup" yapısından "Domain" yapısına evrilmesi gerektiğini mantıksal bir çerçevede açıklıyor.

Neden Windows Domain Kullanıyoruz?

Bir ağın yönetimi, o ağdaki bilgisayar ve kullanıcı sayısı ile doğrudan orantılı bir karmaşıklığa sahiptir. Bu durumu iki farklı senaryo üzerinden analiz edebiliriz:

1. Küçük Ölçekli Ağlar (Workgroup Mantığı)

Sadece 5 bilgisayarı ve 5 çalışanı olan küçük bir işletme düşünelim. Bu senaryoda her bilgisayar bağımsız bir birimdir.

- **Manuel Yönetim:** Her bilgisayara fiziksel olarak gidip oturum açmanız, kullanıcıları tek tek oluşturmanız ve kişiye özel ayarları elle yapmanız gerekir.
- **Yerinde Destek:** Bir sorun çıktığında teknik destek ancak o bilgisayarın başına gidilerek verilebilir.
- **Merkezi Olmayan Yapı:** Her bilgisayar kendi kullanıcı veritabanına (**SAM - Security Account Manager**) sahiptir. A kullanıcısının hesabı sadece bilgisayar 1'de tanımlıysa, bilgisayar 2'de oturum açamaz.

2. Ölçeklenebilirlik Sorunu ve Domain İhtiyacı

İşletme büyüyüp 157 bilgisayara ve 320 kullanıcıya ulaştığında, üstelik bu kullanıcılar 4 farklı ofise dağıldığında manuel yönetim imkansız hale gelir. Her kullanıcı için her bilgisayarda ayrı

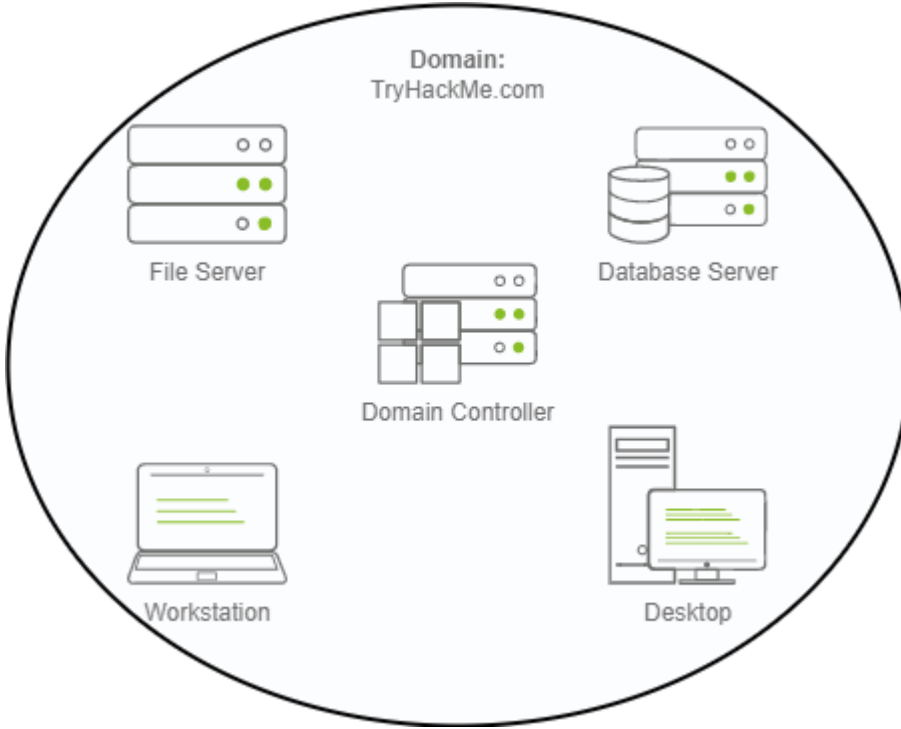
ayrı politika (policy) yapılandırmak veya her sorun için fiziksel olarak orada bulunmak sürdürülebilir değildir.

İşte bu noktada **Windows Domain** devreye girer. Basitçe ifade etmek gerekirse; bir Windows Domain, bir işletmenin yönetimi altındaki kullanıcı ve bilgisayarların oluşturduğu topluluktur.

Temel Bileşenler ve Kavramlar

Domain yapısının kalbinde yönetimi tek bir noktadan yapmamızı sağlayan servisler ve sunucular bulunur:

- **Active Directory (AD):** Windows ağındaki tüm bileşenlerin (kullanıcılar, bilgisayarlar, gruplar, yazıcılar vb.) bilgilerinin tutulduğu merkezi bir depodur (repository). Bir nevi ağın "rehberi" ve "yönetim paneli"dir.
- **Domain Controller (DC):** Active Directory servislerini üzerinde çalıştıran sunucudur. Ağdaki tüm kimlik doğrulama (authentication) ve yetkilendirme (authorization) işlemlerinden sorumlu olan "patron" makinedir.



Windows Domain Kullanmanın Temel Avantajları

Bir yapıyı Domain altına almanın iki ana teknik sütunu vardır:

1. Merkezi Kimlik Yönetimi (Centralised Identity Management)

Ağdaki tüm kullanıcı hesapları tek bir noktadan, yani **Active Directory** üzerinden oluşturulur ve yönetilir.

- **Erişilebilirlik:** Bir kullanıcı, ağa bağlı herhangi bir bilgisayara oturduğunda kendi kullanıcı adı ve şifresiyle giriş yapabilir.

- **Arka Plan İşleyişi:** Siz bir bilgisayarda şifrenizi girdiğinizde, o bilgisayar bu bilgileri doğrulamak için **Domain Controller**'a gönderir. Eğer DC onay verirse oturum açılır. Yani kullanıcı bilgilerinin her bilgisayarda yerel olarak kayıtlı olmasına gerek yoktur.

2. Güvenlik Politikalarının Yönetimi (Managing Security Policies)

Güvenlik ayarlarını ve kısıtlamaları her bilgisayarda tek tek yapmak yerine, bunları **Active Directory** üzerinden bir kez yapılandırıp tüm ağa yayabilirsiniz.

- **GPO (Group Policy Objects):** Örneğin, tüm çalışanların bilgisayarlarında Kontrol Paneli'ne erişimi engellemek veya belirli bir duvar kağıdını zorunlu kılmak istiyorsanız, bunu DC üzerinden tek bir hamleyle yaparsınız.

Gerçek Dünya Örneği: Okul ve Üniversite Ağları

Üniversite kampüslerindeki bilgisayar laboratuvarlarını düşünün. Hangi bilgisayara otursanız oturun, okulun size verdiği tek bir kullanıcı adı ve şifreyle giriş yapabilirsiniz.

- **Süreç:** Siz şifrenizi girdiğiniz anda bilgisayar bu veriyi kampüsteki **Active Directory**'ye yönlendirir. Kimlik doğrulama orada gerçekleşir.
- **Kısıtlamalar:** Okul bilgisayarında "Denetim Masası"na giremiyor olmanızın veya USB takıp dosya çalıştıramıyor olmanızın sebebi, sistem yöneticisinin AD üzerinden bu politikaları (policies) tüm bilgisayarlara uygulamış olmasıdır. Bu sayede siz o bilgisayarda **Administrative Privileges** (Yönetici Yetkileri) sahibi olamazsınız.

Active Directory Domain Service (AD DS)

Windows Domain yapısının kalbi ve beyni **Active Directory Domain Service (AD DS)**'tir. Bu servis, ağdaki tüm varlıkların bilgilerini tutan devasa bir "katalog" veya "rehber" görevi görür. AD içinde bulunan her bir varlığa **Object (Nesne)** denir.

Active Directory Nesne Türleri

Ağdaki her şey bir nesne olarak tanımlanır. Ancak bazı nesneler sadece bilgi tutmakla kalmaz, ağ üzerinde işlem yapma yeteneğine de sahiptir.

1. Users (Kullanıcılar)

AD içindeki en temel nesne türüdür. Kullanıcılar birer **Security Principal** (Güvenlik Sorumlusu) olarak kabul edilir.

- **Security Principal Nedir?:** Etki alanı (domain) tarafından kimliği doğrulanabilen ve dosya, yazıcı gibi **Resource** (Kaynaklar) üzerinde yetki atanabilen nesnelerdir. Kısacası; ağda "aksiyon alan" varlıklardır.

Kullanıcı nesneleri iki farklı varlığı temsil edebilir:

- **Kişiler:** Şirket çalışanları (Örn: Ahmet, Ayşe).
- **Servisler:** **IIS** (Web sunucusu) veya **MSSQL** (Veritabanı) gibi servislerin çalışması için gereken özel hesaplar. Servis hesapları, sadece o servisi çalıştıracak kısıtlı yetkilere sahip olacak şekilde yapılandırılır.

2. Machines (Makineler / Bilgisayarlar)

Domain'e dahil olan her bilgisayar için AD içinde otomatik olarak bir makine nesnesi oluşturulur.

- **İlginç Detay:** Makineler de birer **Security Principal**'dir! Tıpkı kullanıcılar gibi onların da bir hesabı ve şifresi vardır.
- **Yetki:** Makine hesapları, üzerinde bulundukları bilgisayarda **Local Administrator** (Yerel Yönetici) yetkisine sahiptir.
- **Şifre Yönetimi:** Bu hesapların şifreleri kullanıcılar tarafından bilinmez. Windows bu şifreleri 30 günde bir otomatik olarak yaklaşık **120 karakterlik** rastgele dizilerle değiştirir.
- **İsimlendirme Standardı:** Bir makine hesabını isminin sonundaki **\$** işaretinden tanırırsınız.
 - Bilgisayar adı: DC01
 - Makine hesap adı: DC01\$

3. Security Groups (Güvenlik Grupları)

Yetki yönetimini kolaylaştırmak için kullanılır. Her kullanıcıya tek tek izin vermek yerine, kullanıcıları bir gruba toplar ve izni gruba verirsiniz. Gruplar da birer **Security Principal**'dir.

- **Kapsam:** Grupların içine kullanıcılar, makineler ve hatta başka gruplar (Nested Groups) eklenebilir.
- **Miras (Inheritance):** Bir kullanıcıyı bir gruba eklediğinizde, o grubun sahip olduğu tüm yetkileri otomatik olarak devralır.

Kritik Varsayılan Gruplar (Default Groups)

Domain kurulduğunda otomatik gelen bazı hayati gruplar şunlardır:

Güvenlik Grubu	Açıklama
Domain Admins	Tüm domain üzerinde tam yetkilidir. DC'ler dahil her bilgisayarı yönetebilirler.
Server Operators	Domain Controller'ları yönetebilirler ancak grup üyeliklerini değiştiremezler.
Backup Operators	Dosya izinlerini yok sayarak her dosyaya erişebilirler (Yedekleme amaçlı).
Account Operators	Domain'de yeni hesap oluşturabilir veya mevcut hesapları düzenleyebilirler.

Güvenlik Grubu	Açıklama
Domain Users	Domain'deki tüm kullanıcı hesaplarını kapsar.
Domain Computers	Domain'e dahil tüm bilgisayarları kapsar.

Yönetim Araçları: Active Directory Users and Computers (ADUC)

Domain nesnelerini yönetmek için Domain Controller (DC) üzerinde **Active Directory Users and Computers** aracı kullanılır. Bu araç, domain yapısını hiyerarşik bir şekilde görmemizi sağlar.

Organizational Units (OU - Kuruluş Birimleri)

OU'lar, nesneleri (kullanıcılar, makineler vb.) mantıksal olarak gruplandırmak için kullanılan "konteyner" nesnelerdir. Genellikle şirketin departman yapısını (Bilgi İşlem, Satış, İK) yansıtırlar.

- **Neden Kullanılır?:** Benzer politika gereksinimleri olan kullanıcıları bir arada tutmak için. Satış departmanına farklı, Yazılım departmanına farklı kısıtlamalar (GPO) uygulanabilir.
- **Önemli Kural:** Bir nesne (kullanıcı veya bilgisayar) aynı anda **sadece bir OU** içerisinde bulunabilir.

Varsayılan Konteynerler

ADUC açıldığında gelen standart klasörler şunlardır:

- **Builtin:** Windows'un standart yerel grupları.
- **Computers:** Domain'e yeni katılan makinelerin varsayılan durağı.
- **Domain Controllers:** Ağdaki DC'lerin listelendiği özel OU.
- **Users:** Domain genelindeki varsayılan kullanıcı ve gruplar.
- **Managed Service Accounts:** Servisler tarafından kullanılan özel hesapların tutulduğu yer.

Kritik Fark: Security Group vs. OU

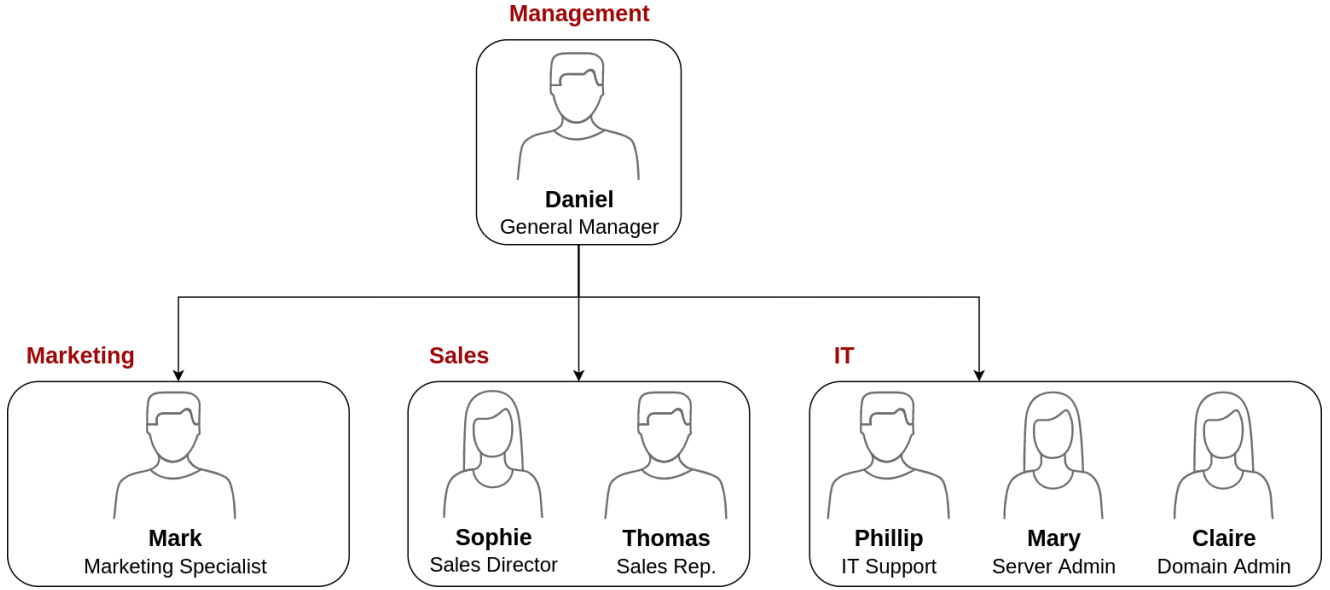
Bu iki kavram sıkça karıştırılır, ancak görevleri tamamen farklıdır:

1. **Organizational Units (OU): Politika (Policy)** uygulamak için kullanılır. (Örn: "Pazarlama departmanındaki herkesin masaüstü arka planı şirket logosu olsun.")
2. **Security Groups: Erişim Yetkisi (Permission)** vermek için kullanılır. (Örn: "Bu klasöre sadece 'Muhasebe_Grup' üyeleri okuma yetkisiyle erişebilirsin.")

Unutma: Bir kullanıcı birden fazla **Gruba** üye olabilir (farklı kaynaklara erişmek için), ancak sadece tek bir **OU** içinde bulunabilir (tek bir ana politika setine tabi olmak için).

Active Directory'de Kullanıcı ve OU Yönetimi

Bir Domain Administrator (Etki Alanı Yöneticisi) olarak en temel görevlerimizden biri, organizasyon şemasındaki değişiklikleri Active Directory (AD) yapısına yansıtmaktır. Bu bölümde gereksiz bir birimin silinmesi ve yetki devri (**Delegation**) süreçlerini teknik detaylarıyla ele alacağız.



1. Organizasyonel Birimlerin (OU) Silinmesi

Bütçe kesintileri gibi nedenlerle kapanan bir departmanı AD'den silmek istediğinizde, Windows'un yerleşik koruma mekanizmasıyla karşılaşacaksınız.

Yanlışlıkla Silmeye Karşı Koruma

Varsayılan olarak AD içindeki her OU, "Accidental Deletion" (Yanlışlıkla Silme) korumasıyla oluşturulur. Bir OU'ya sağ tıklayıp "Delete" dediğinizde erişim engellendi hatası alıyorsanız, şu adımları izlemelisiniz:

1. **Görünümü Değiştir:** **Active Directory Users and Computers (ADUC)** penceresinde üst menüden **View > Advanced Features** (Gelişmiş Özellikler) seçeneğini aktif edin. Bu seçenek aktif olmazsa nesnenin koruma sekmelerini göremezsiniz.
2. **Korumayı Kaldır:** Silmek istediğiniz OU'ya sağ tıklayıp **Properties** (Özellikler) deyin.
3. **Nesne Ayarları:** Açılan pencerede **Object** sekmesine gidin.
4. **Onayı Kaldır:** "**Protect object from accidental deletion**" kutusundaki işareti kaldırın ve **OK** butonuna basın.

Bu işlemten sonra sağ tıklayıp **Delete** dediğinizde, o OU ve içindeki tüm alt nesneler (kullanıcılar, gruplar) kalıcı olarak silinecektir.

2. Yetki Devri (Delegation of Control)

Her küçük işlem için (şifre sıfırlama gibi) Domain Administrator hesabını kullanmak güvenlik açısından risklidir (**Least Privilege** prensibi). Bunun yerine, belirli yetkileri belirli kullanıcılara

devretmeliyiz.

Senaryo: IT Support Yetkilendirmesi

BT destek ekibinden **Phillip**'in, **Sales (Satış)** birimindeki kullanıcıların şifrelerini sıfırlayabilmesini istiyoruz.

Adımlar:

1. **ADUC** üzerinden hedef OU'ya (**Sales**) sağ tıklayın ve **Delegate Control...** seçeneğini seçin.
2. **Kullanıcı Seçimi:** Çıkan sihirbazda Phillip'i ekleyin. (İpucu: **phillip** yazıp **Check Names** butonuna basmak, hata yapmanızı engeller).
3. **Görev Seçimi:** Listedten **"Reset user passwords and force password change at next logon"** (Kullanıcı şifrelerini sıfırla ve bir sonraki oturumda şifre değişimine zorla) seçeneğini işaretleyin.

Artık Phillip, Satış departmanındaki kullanıcıların şifrelerini yönetebilir ancak tüm domain üzerinde tam yetkili değildir.

3. Yetki Devrini Powershell ile Test Etme

Phillip'in hesabı ile oturum açtığınızda, grafik arayüzlü AD araçlarını (ADUC) açma yetkisi olmayabilir. Ancak kendisine delege edilen yetkiyi **PowerShell** üzerinden kullanabilir.

Kullanıcı Şifresini Sıfırlama

Phillip olarak giriş yaptıktan sonra, **Sophie** adlı kullanıcının şifresini şu komutla sıfırlayabiliriz:

PowerShell

```
Set-ADAccountPassword sophie -Reset -NewPassword (Read-Host -AsSecureString  
-Prompt 'New Password') -Verbose
```

- **Set-ADAccountPassword:** Şifre değiştirme/sıfırlama komutu.
- **-Reset:** Şifreyi mevcut olanı bilmeden sıfırlayacağımızı belirtir.
- **-NewPassword (...):** Yeni şifreyi güvenli bir giriş ekranından alır.
- **-Verbose:** İşlemin detaylarını (hangi nesnenin etkilendiği gibi) ekrana basar.

Bir Sonraki Oturumda Şifre Değişimini Zorunlu Kılma

Sıfırladığımız şifreyi bizim bilmemiz bir güvenlik açığıdır. Bu yüzden Sophie'nin ilk oturumda şifresini değiştirmesini sağlamalıyız:

PowerShell

```
Set-ADUser -ChangePasswordAtLogon $true -Identity sophie -Verbose
```

- **-ChangePasswordAtLogon \$true:** Kullanıcının ilk girişte şifre değiştirme ekranına yönlendirilmesini sağlar.
- **-Identity sophie:** Hedef kullanıcıyı belirtir.

Kritik Hatırlatmalar

- **RDP Girişi:** Domain ortamında RDP yaparken kullanıcı adını DOMAIN\KullanıcıAdı (Örn: THM\phillip) şeklinde yazmalısınız. Aksi takdirde bilgisayar sizi yerel bir kullanıcı sanabilir.
- **Mantıksal Bağ:** Phillip'e yetkiyi Sales OU'su üzerinde verdik. Eğer Sophie başka bir OU'da olsaydı, Phillip'in komutları hata verecekti. Yetki devri **konum (OU)** bazlıdır.

Active Directory'de Bilgisayar Yönetimi ve Nesne Organizasyonu

Domain ortamında sadece kullanıcıları değil, ağa dahil olan tüm makineleri de yönetiyoruz. Varsayılan yapılandırmada, domaine katılan her cihaz (Domain Controller'lar hariç) otomatik olarak **Computers** konteynerine atılır. Ancak profesyonel bir yönetimde bu kabul edilebilir bir durum değildir.

1. Makineleri Neden Gruplandırmalıyız?

Tıpkı kullanıcılar gibi, bilgisayarların da ağ üzerindeki rolleri ve güvenlik gereksinimleri farklıdır. Bir dosya sunucusu (**Server**) ile bir sekreterin bilgisayarını (**Workstation**) aynı politikalara (GPO) tabi tutulmamalıdır.

Makineleri organize ederken genel kabul görmüş üç ana kategori vardır:

- **Workstations (İş İstasyonları):** Son kullanıcıların günlük işlerini yaptığı, internete çıktığı cihazlardır. Bu cihazlarda asla yüksek yetkili (Privileged) hesaplarla (Domain Admin gibi) oturum açılmamalıdır.
- **Servers (Sunucular):** Kullanıcılara veya diğer sistemlere servis (IIS, SQL, File Server vb.) sağlayan makinelerdir.
- **Domain Controllers (DC):** Ağın beynidir. Tüm kullanıcı şifrelerinin hash'lerini barındırdıkları için ağdaki **en kritik** ve hassas cihazlardır.

2. OU Yapısının Tasarlanması ve Taşıma İşlemi

Yeni bir domain yöneticisi olarak ilk işimiz, karmaşık durumdaki **Computers** konteynerini temizlemek ve makineleri rollerine göre ayırmaktır.

Yeni OU'ların Oluşturulması

Hiyerarşiyi düzenlemek için `thm.local` kök dizini altında iki yeni **Organizational Unit (OU)** oluşturuyoruz:

1. **Workstations**
2. **Servers**

Not: Domain Controller makineleri zaten Windows tarafından otomatik olarak oluşturulan ve kendine has kritik politikaları olan **Domain Controllers** OU'su altındadır. Onlara dokunmuyoruz.

Nesnelerin Taşınması (Drag & Drop)

Computers konteynerine girdiğinizde karşınıza karışık bir liste çıkar. Buradaki makineleri mantıksal rollerine göre yeni yuvalarına taşımalıyız:

- **Laptop ve PC'ler:** Kullanıcıların şahsi cihazlarını ve dizüstü bilgisayarlarını tutup **Workstations** OU'suna sürüklüyoruz.
- **Sunucular:** Uygulama veya servis barındıran makineleri seçip **Servers** OU'suna taşıyoruz.

3. Neden Konteyner Yerine OU?

Makinelerin ilk katıldığında gittiği "**Computers**" bir konteynerdir, bir OU değildir. Aradaki en büyük fark şudur:

- **Konteynerlere (Computers gibi) doğrudan Group Policy Object (GPO) atanamaz.**
- Eğer makineleri `Computers` içinde bırakırsanız, sunuculara özel veya workstation'lara özel ayrı ayrı merkezi kısıtlamalar uygulayamazsınız.

Makineleri kendi oluşturduğumuz **OU**'lara taşıyarak, ileride şu senaryoları gerçekleştirebiliriz:

- **Workstations OU'su için:** "USB takılmasını engelle, ekran koruyucuyu 5 dakikaya ayarla."
- **Servers OU'su için:** "Sadece sistem yöneticileri RDP yapabilsin, otomatik güncellemeleri şu saatte yap."

Kritik Teknik Özet

1. **Varsayılan Durum:** Yeni eklenen her makine `CN=Computers,DC=thm,DC=local` yoluna gider.
2. **Düzenleme:** `Advanced Features` açıkken nesneleri tutup ilgili OU'ya bırakmak yeterlidir.
3. **Güvenlik Mantiği:** Cihazları rollerine göre ayırmak, **Yanal Hareket (Lateral Movement)** saldırılarını engellemek için atılan ilk adımdır. Bir saldırgan bir workstation'ı ele geçirdiğinde, o makineye uygulanan kısıtlı politikalar sayesinde sunucu tarafına geçmekte zorlanacaktır.

Group Policy Objects (GPO) - Grup Politikaları

Domain yapısını sadece kullanıcıları ve bilgisayarları klasörlere ayırmak için kurmadık; asıl amacımız bu yapıları **merkezi olarak yönetmek**. İşte bu noktada devreye **GPO (Group Policy Objects)** girer. GPO'lar, belirli bir OU (Organizational Unit) içindeki nesnelere uygulanan ayarlar bütünüdür.

1. GPO Temelleri ve Yönetimi

GPO'ları yönetmek için Başlat menüsünden **Group Policy Management** aracı kullanılır. Bu araçta, daha önce oluşturduğumuz OU hiyerarşisini görürüz.

Mantık Akışı:

1. **GPO Oluşturma:** Önce "Group Policy Objects" klasörü altında içi boş bir GPO oluşturulur.
2. **Yapılandırma:** GPO düzenlenerek içine kurallar (şifre uzunluğu, masaüstü kısıtlamaları vb.) eklenir.
3. **Linkleme (Bağlama):** Hazırlanan GPO, uygulanması istenen OU'nun üzerine sürüklenerek bağlanır.

Miras Alma (Inheritance) ve Kapsam (Scope)

- **Miras:** Bir GPO bir üst klasöre (Domain kökü gibi) bağlandığında, altındaki tüm alt OU'lara otomatik olarak sirayet eder. Örneğin, en üstteki **thm.local**'e bağlanan bir politika, **Sales** ve **Marketing** OU'larını da etkiler.
- **Security Filtering (Güvenlik Filtreleme):** Bir GPO bir OU'ya bağlı olsa bile, sadece o OU içindeki belirli grup veya kullanıcılara uygulanması sağlanabilir. Varsayılan olarak **Authenticated Users** (Doğrulanmış Kullanıcılar) grubuna uygulanır, yani herkesi kapsar.

2. GPO İçeriği: User vs. Computer Configuration

Her GPO iki ana bölüme ayrılır:

- **Computer Configuration:** Bilgisayar açıldığı anda uygulanır. Bilgisayara kimin girdiği fark etmeksizin geçerlidir (Örn: Şifre politikaları, Windows güncellemeleri).
- **User Configuration:** Kullanıcı oturum açtığı anda uygulanır. Kullanıcının hangi bilgisayara oturduğu fark etmeksizin peşinden gelir (Örn: Kontrol Paneli kısıtlaması, masaüstü arka planı).

Örnek: Default Domain Policy Düzenleme

Domain genelinde minimum şifre uzunluğunu 10 karakter yapmak istiyorsak:

1. **Edit:** GPO'ya sağ tıkla -> Edit.

2. **Yol:** Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Account Policies -> Password Policy .
3. **Değişiklik:** "Minimum password length" değerini 10 yap.

3. GPO Dağıtımı ve Güncellenmesi

GPO ayarları, Domain Controller üzerindeki **SYSVOL** adı verilen özel bir paylaşılan klasörde saklanır (Varsayılan yol: C:\Windows\SYSVOL\sysvol\). Ağdaki tüm bilgisayarlar bu klasöre erişerek periyodik olarak politikalarını senkronize eder.

- **Zamanlama:** Yapılan bir değişikliğin tüm ağa yayılması **2 saati** bulabilir.
- **Zorlama (Force Update):** Bir bilgisayarda ayarların hemen geçerli olmasını istiyorsanız PowerShell/CMD üzerinden şu komutu çalıştırın:

PowerShell

```
gpupdate /force
```

4. Uygulama: THM Inc. İçin Yeni Politikalar

Şirket bizden iki kritik kısıtlama istedi:

A. Kontrol Paneli Erişimini Kısıtlama

Amaç: IT dışındaki kullanıcıların sistem ayarlarını kurcalamasını engellemek.

1. **Yeni GPO:** "Restrict Control Panel Access" adında bir GPO oluşturun.
2. **Ayar:** User Configuration -> Policies -> Administrative Templates -> Control Panel altındaki **"Prohibit access to Control Panel and PC settings"** seçeneğini **Enabled** yapın.
3. **Linkleme:** Bu GPO'yu **Marketing, Management** ve **Sales** OU'larına sürükleyip bağlayın. (IT OU'suna bağlamıyoruz ki onlar erişebilsin).

B. Otomatik Ekran Kilidi

Amaç: Bilgisayar başında 5 dakika işlem yapılmazsa ekranın otomatik kilitlenmesini sağlamak.

1. **Yeni GPO:** "Auto Lock Screen" adında bir GPO oluşturun.
2. **Ayar:** Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Local Policies -> Security Options altındaki **"Interactive logon: Machine inactivity limit"** değerini **300 saniye (5 dakika)** olarak ayarlayın.
3. **Linkleme:** Bu politika tüm makineleri (Sunucular dahil) kapsamalıdır. Bu yüzden doğrudan en üste, **thm.local** domain köküne bağlayın. Altındaki tüm Computer nesneleri bu politikayı miras alacaktır.

Teknik Analiz ve Doğrulama

Kısıtlamaları test etmek için **Mark** (Marketing departmanında) kullanıcısı ile RDP yapıldığında:

- Kontrol Paneli'ni açmaya çalışıldığında "Bu işlem kısıtlanmıştır" uyarısı alır.
- Bilgisayarı 5 dakika bırakırsa oturum kilitlenir.

Kritik Not: Eğer GPO'yu en üste bağladıysanız ve içinde sadece "Computer Configuration" varsa, bu GPO'nun altındaki sadece "User" içeren OU'lara (Örn: Sales) bir zararı olmaz; çünkü kullanıcı nesneleri bilgisayar ayarlarını görmezden gelir.

Authentication Methods (Kimlik Doğrulama Yöntemleri)

Windows Domain yapısında kritik bir kural vardır: **Tüm kimlik bilgileri (credentials) Domain Controller (DC) üzerinde saklanır.**

Bu ne demek? Eğer ben bir kullanıcı olarak ağdaki bir servise (örneğin bir dosya paylaşımına veya veritabanına) erişmek istersem, o servisin benim kimliğimi doğrulamak için gidip DC'ye sorması gerekir. Çünkü benim şifremi o servis bilmiyor, sadece DC biliyor.

Windows ağlarında bu işi yapan iki temel protokol vardır:

1. **Kerberos:** Modern Windows sürümlerinin varsayılanıdır. Standart budur.
2. **NetNTLM:** Eski (legacy) bir protokoldür. Uyumluluk (compatibility) için tutulur ama artık "obsolete" (kullanımdan kalkmış) kabul edilmelidir. Yine de çoğu ağda ikisi de aktiftir.

Şimdi bu iki protokolün nasıl çalıştığını, kaputun altına girerek inceleyelim. Buradaki detaylar saldırı vektörlerini (Kerberoasting, Pass-the-Hash vb.) anlamak için **hayati** önem taşıyor.

1. Kerberos Authentication

Kerberos, modern Windows'un varsayılanıdır ve mantığı tamamen **Biletler (Tickets)** üzerine kuruludur.

- **Mantık:** Bir kez kimliğini kanıtladıktan sonra, bir bilet alır. Sonra her yere bu bileti göstererek girer.
- **Neden?** Her servise (Yazıcı, SQL, Dosya Sunucusu) bağlanırken tekrar tekrar şifre girmek ve şifreyi ağda dolaştırmamak için.

Sürecin merkezinde **KDC (Key Distribution Center)** bulunur. KDC, genellikle Domain Controller üzerinde çalışan ve biletleri dağıtan servistir.

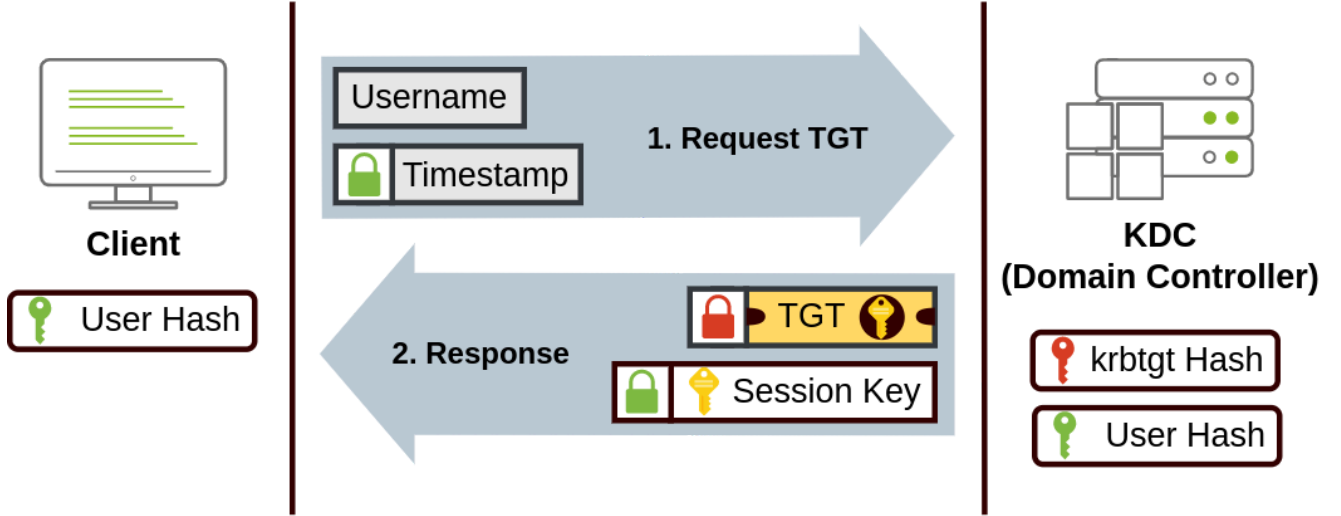
Kerberos Süreci (Adım Adım Derinlemesine Analiz)

Bu akışa "Kerberos Handshake" denir ve sırasıyla şöyle işler:

Adım 1: İlk Kimlik Doğrulama (Authentication Service Request)

Kullanıcı bilgisayarı açar ve şifresini girer.

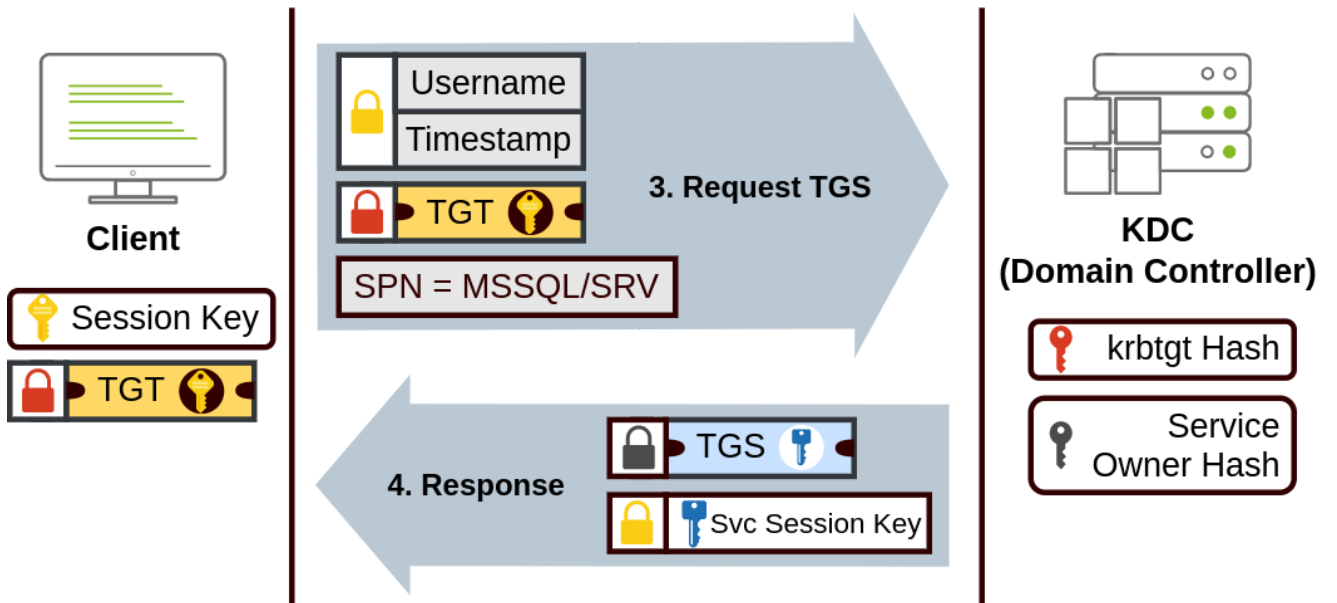
- Kullanıcı, **Kullanıcı Adı + Zaman Damgası (Timestamp)** bilgisini paketler.
- Bu paketi, **kendi şifresinden türetilen bir anahtarla (Hash)** şifreleyerek KDC'ye gönderir.



Adım 2: TGT (Ticket Granting Ticket) Alımı

KDC, gelen paketi kullanıcının veritabanındaki şifre hash'i ile açmaya çalışır. Açabiliyorsa kimlik doğrudur. KDC kullanıcıya iki şey gönderir:

- TGT (Ticket Granting Ticket):** Bu "Ana Bilet"tir. Diğer servis biletlerini almak için kullanılır.
 - KRİTİK DETAY:** TGT, **krbtgt** hesabının (Domain'in gizli servisi) şifre hash'i ile şifrelenmiştir. **Kullanıcı bu biletin içeriğini okuyamaz veya değiştiremez.** Sadece saklar ve KDC'ye geri gösterir.
- Session Key (Oturum Anahtarı):** Kullanıcının KDC ile sonraki iletişimlerinde kullanacağı geçici anahtar.



Not: KDC, Session Key'in bir kopyasını TGT'nin içine de koyar. Böylece KDC, "bu adamın session key'i neydi?" diye hafızasında tutmak zorunda kalmaz. TGT geldiğinde şifresini çözer ve içinden anahtarı okur (Stateless yapı).

Adım 3: Servis Bileti İsteği (Ticket Granting Service Request)

Kullanıcı şimdi ağdaki bir kaynağa (örn: Dosya Sunucusu) erişmek istiyor.

- Elindeki **TGT**'yi KDC'ye gönderir.
- Yanına da erişmek istediği servisin adını (**SPN - Service Principal Name**) ve **Session Key** ile şifrelenmiş bir doğrulayıcı (Authenticator) ekler.

Adım 4: TGS (Ticket Granting Service) Alımı

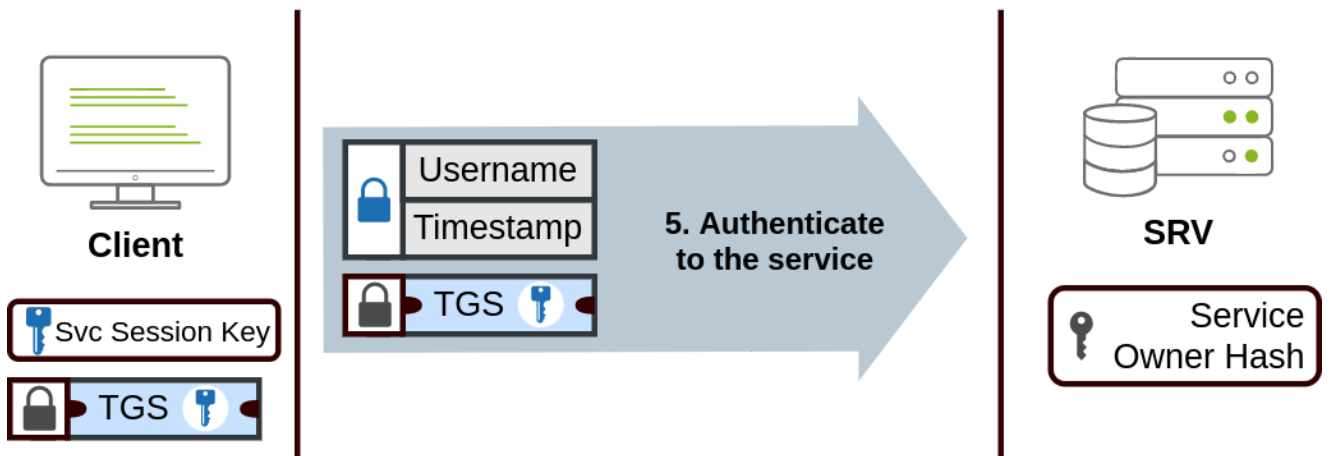
KDC, TGT'yi `krbtgt` anahtarıyla çözer, geçerli mi bakar. Eğer her şey tamamsa, kullanıcıya o servise özel bir bilet (**TGS**) üretir.

- KDC kullanıcıya yine iki şey döner:
 1. **TGS Bileti:** Hedef servise giriş kartıdır.
 - **KRİTİK DETAY:** TGS, servisin çalıştığı hesabın (**Service Owner Hash**) şifresiyle şifrelenmiştir.
 - Bu biletin içinde, kullanıcı ve servisin güvenli konuşması için yeni bir **Service Session Key** saklıdır.
 2. **Service Session Key:** Kullanıcının servis ile konuşurken kullanacağı anahtar (Kullanıcıya ayrıca, kendi session key'i ile şifrelenmiş olarak gönderilir).

Adım 5: Servis Erişim (Application Request)

Kullanıcı artık KDC ile işini bitirdi. Elindeki **TGS**'yi alır ve doğrudan hedef servise (örn: Dosya Sunucusu) gönderir.

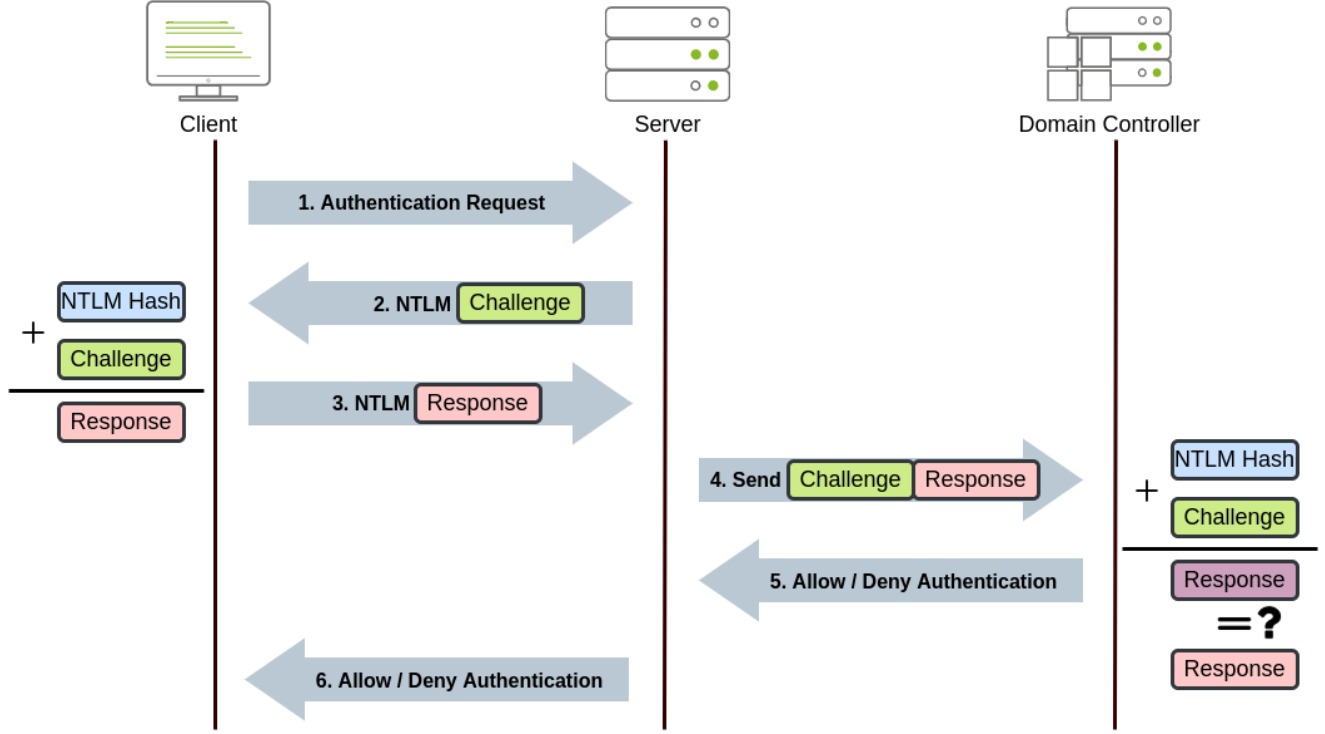
- Servis, kendi şifre hash'ini kullanarak TGS'yi çözer (Decryption).
- İçinden **Service Session Key**'i çıkarır.
- Kullanıcıyı doğrular ve kapıyı açar.



2. NetNTLM Authentication

NetNTLM, Kerberos'un aksine bilet mantığıyla değil, **Challenge-Response (Meydan Okuma - Yanıt)** mantığıyla çalışır. Eski bir yöntemdir ama hala her yerdedir.

NetNTLM Süreci (Adım Adım)



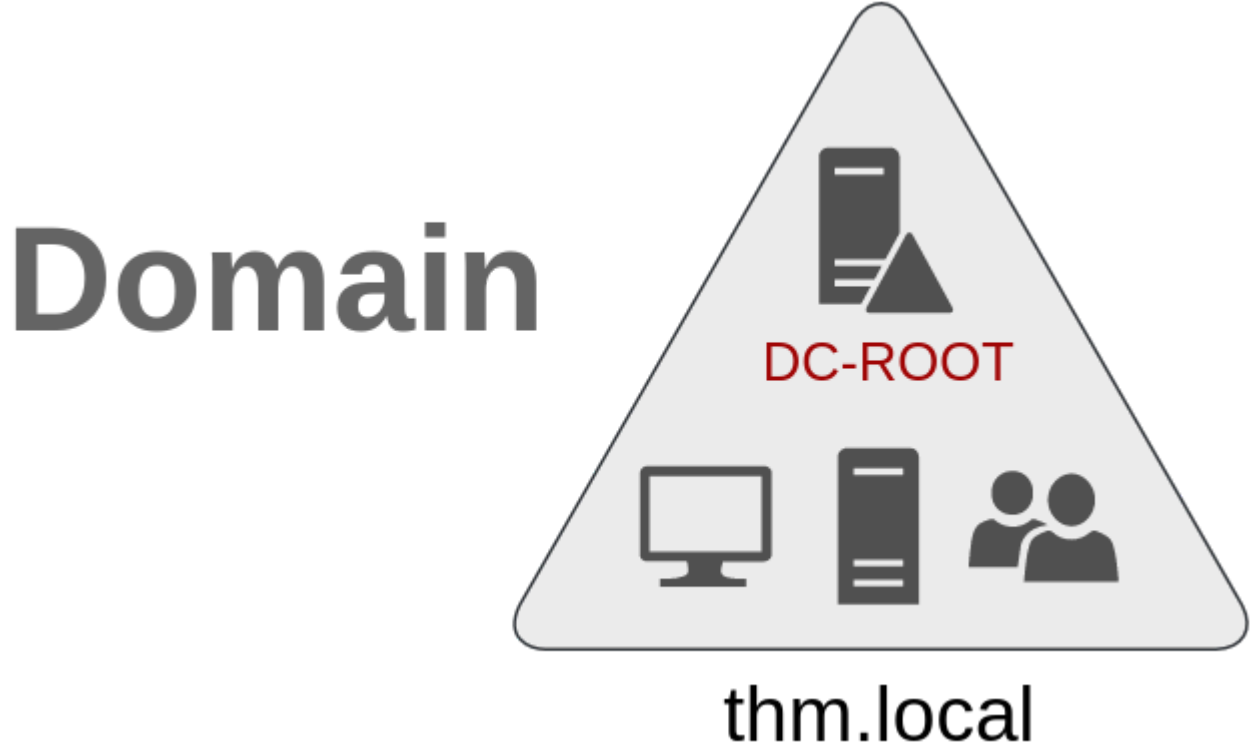
- 1. İstek (Request):** İstemci (Client), sunucuya (Server) "Ben geldim, içeri girmek istiyorum" der.
- 2. Meydan Okuma (Challenge):** Sunucu, istemciye rastgele bir sayı dizisi (Random Number) gönderir. Buna "Challenge" denir.
- 3. Yanıt (Response):**
 - İstemci, bu rastgele sayıyı alır.
 - Kendi **NTLM Şifre Hash**'i ile bu sayıyı matematiksel bir işleme sokar (Encrypt eder).
 - Oluşan sonucu (Response) sunucuya geri gönderir.
- 4. Doğrulama (Verification):**
 - Sunucu, kullanıcının şifresini bilmez. O yüzden gelen "Response"u ve kendi gönderdiği "Challenge"ı alır, **Domain Controller**'a iletir.
 - DC, veritabanından kullanıcının hash'ini bulur.
 - DC, Challenge'ı kullanıcının hash'i ile işleme sokar.
 - Kendi bulduğu sonuç ile sunucudan gelen "Response" aynı mı diye bakar.
- 5. Sonuç:**
 - Eşleşirse DC sunucuya "Tamamdır, al içeri" der.
 - Sunucu da istemciye erişim izni verir.

Güvenlik Notu: NetNTLM sürecinde kullanıcının şifresi veya hash'i ağ üzerinde **asla** çıplak halde gezmez. Sadece Challenge ile harmanlanmış bir "Response" gezer.

Domain vs Yerel Hesap: Eğer bir **Domain Hesabı** değil de o bilgisayarın **Yerel Hesabı (Local Account)** ile giriş yapılıyorsa, sunucu 4. adımda DC'ye gitmez. Kendi üzerindeki **SAM (Security Account Manager)** veritabanına bakar ve doğrulamayı kendisi yapar.

Trees, Forests and Trusts (Ağaçlar, Ormanlar ve Güven İlişkileri)

Şu ana kadar tek bir domain yapısını ve bunun nasıl yönetildiğini inceledik. Ancak şirketler büyüdükçe, tek bir domain yapısı yetersiz kalabilir veya yönetimi zorlaşabilir. Bu noktada Active Directory'nin ölçeklenebilir yapı taşları olan **Trees (Ağaçlar)** ve **Forests (Ormanlar)** devreye girer.



Neden Birden Fazla Domain?

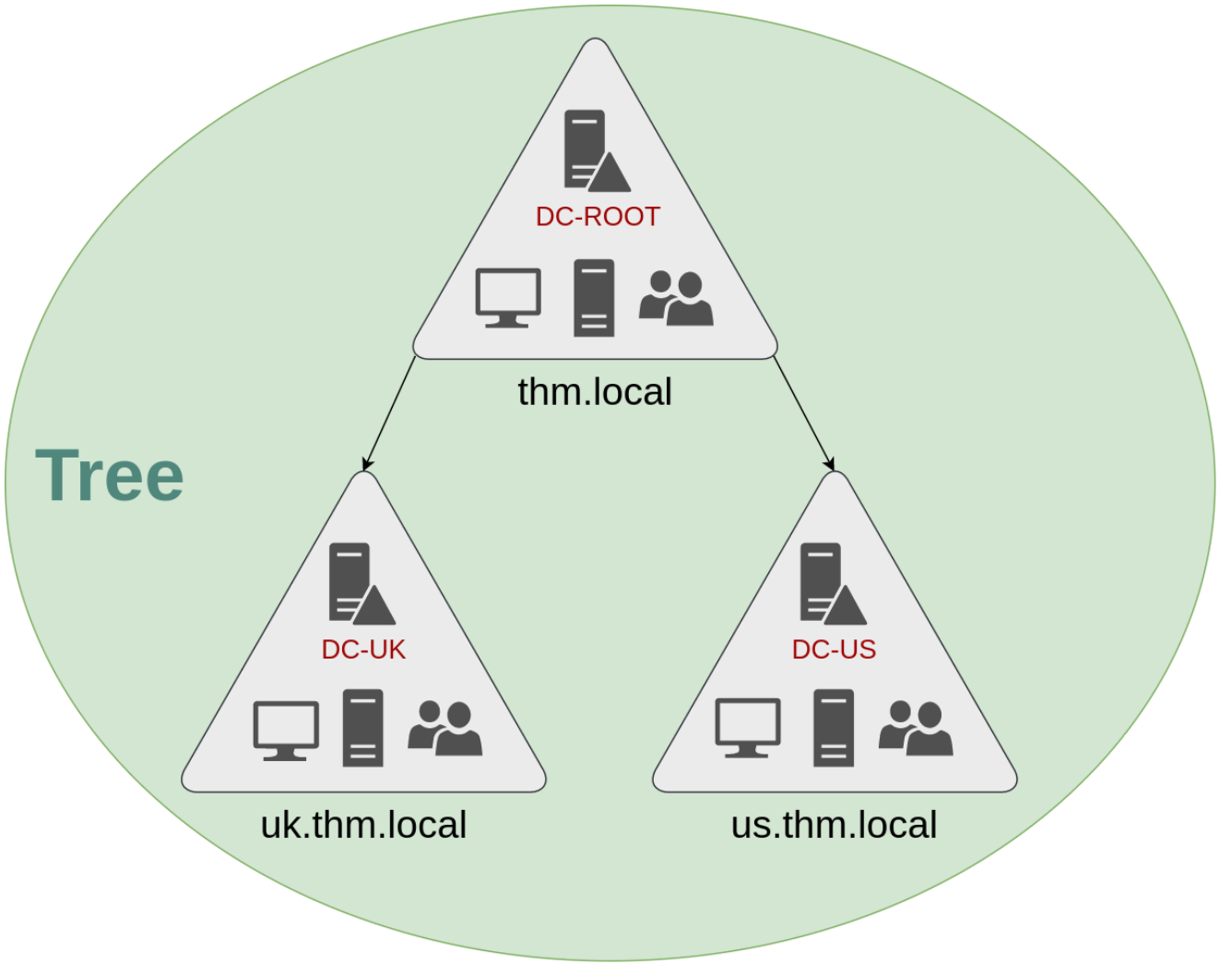
Küçük bir şirkette tek domain (`thm.local`) yeterlidir. Ancak şirket büyüdüğünde veya uluslararası hale geldiğinde şu sorunlar ortaya çıkar:

- **Yasal ve Regülasyon Farkları:** İngiltere şubesi ile ABD şubesinin uyması gereken siber güvenlik yasaları farklı olabilir. Tek domainde farklı GPO'lar basmak karmaşıklaşır.
- **Yönetim Ayrılığı:** İngiltere'deki IT ekibi sadece kendi kullanıcılarını yönetmeli, ABD'deki ekibin işine karışmamalıdır. Delegasyon (yetki devri) ile bu yapılabilir ama hata yapmaya çok açıktır.

Çözüm: Ağ yönetilebilir, bağımsız parçalara (Partition) bölmek.

1. Trees (Ağaçlar)

Eğer birden fazla domain **aynı isim alanını (namespace)** paylaşıyorsa, bu yapıya **Tree** denir.



Örnek Senaryo:

- Ana Domain (Root): `thm.local`
- İngiltere Şubesi: `uk.thm.local`
- ABD Şubesi: `us.thm.local`

Bu yapıda:

- Her alt domainin (Child Domain) kendi **Active Directory** veritabanı, kendi kullanıcıları ve kendi bilgisayarları vardır.
- **Yönetim Bağımsızlığı:** İngiltere'deki Domain Admins sadece `uk.thm.local` üzerinde tam yetkilidir. ABD sunucularına karışamazlar.
- **Politika Bağımsızlığı:** Her domain kendi GPO'larını bağımsız olarak belirleyebilir.

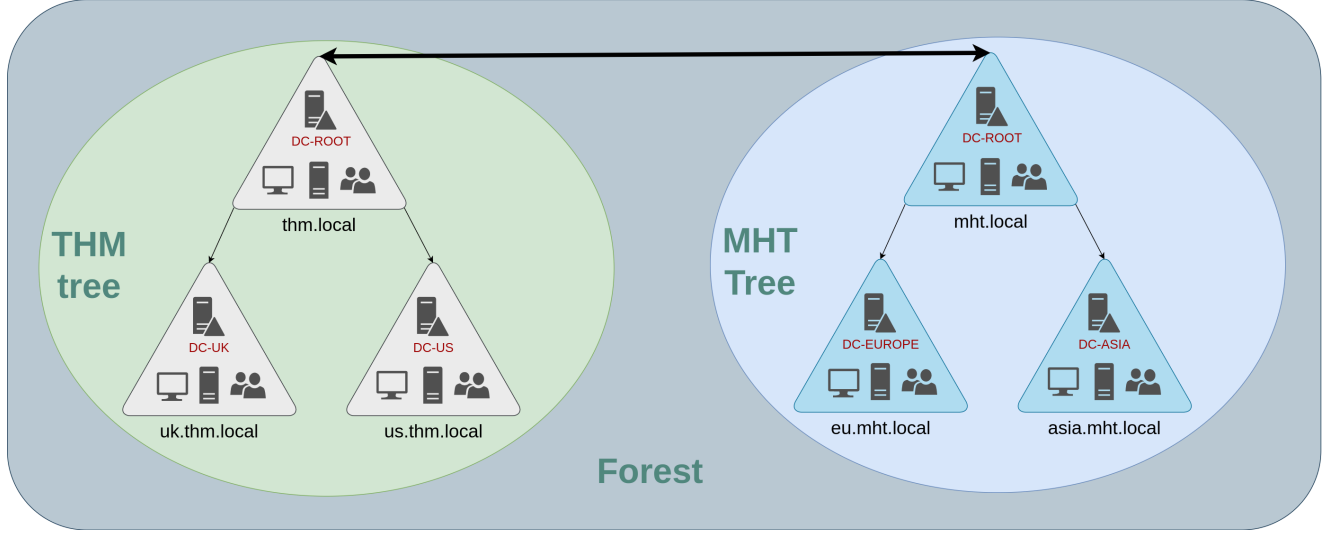
Yeni Bir Yetki Grubu: Enterprise Admins

Tek domain varken en yetkili grup **Domain Admins** idi. Ancak ağaç yapısına geçince, tüm ağaç üzerinde (tüm domainlerde) yetkili olan bir süper grup ortaya çıkar: **Enterprise Admins**.

- **Domain Admins:** Sadece kendi domainini yönetir.
- **Enterprise Admins:** Tüm ağaçtaki (ve ormandaki) her şeyi yönetir.

2. Forests (Ormanlar)

Şirketiniz daha da büyüdü ve başka bir şirketi (**MHT Inc.**) satın aldı. Bu yeni şirketin kendi domain yapısı (`mht.local`) var ve sizin isim alanınızla (`thm.local`) hiç alakası yok.



Farklı isim alanlarına (Namespace) sahip birden fazla **Tree**'nin bir araya gelmesiyle oluşan yapıya **Forest (Orman)** denir.

- **THM Tree:** `thm.local` , `uk.thm.local`
- **MHT Tree:** `mht.local` , `asia.mht.local`
- **Forest:** Her ikisinin birleşimi.

Bu sayede iki şirket birleşse bile, kendi IT departmanları ve domain yapılarını koruyarak tek bir çatı altında toplanabilirler.

3. Trust Relationships (Güven İlişkileri)

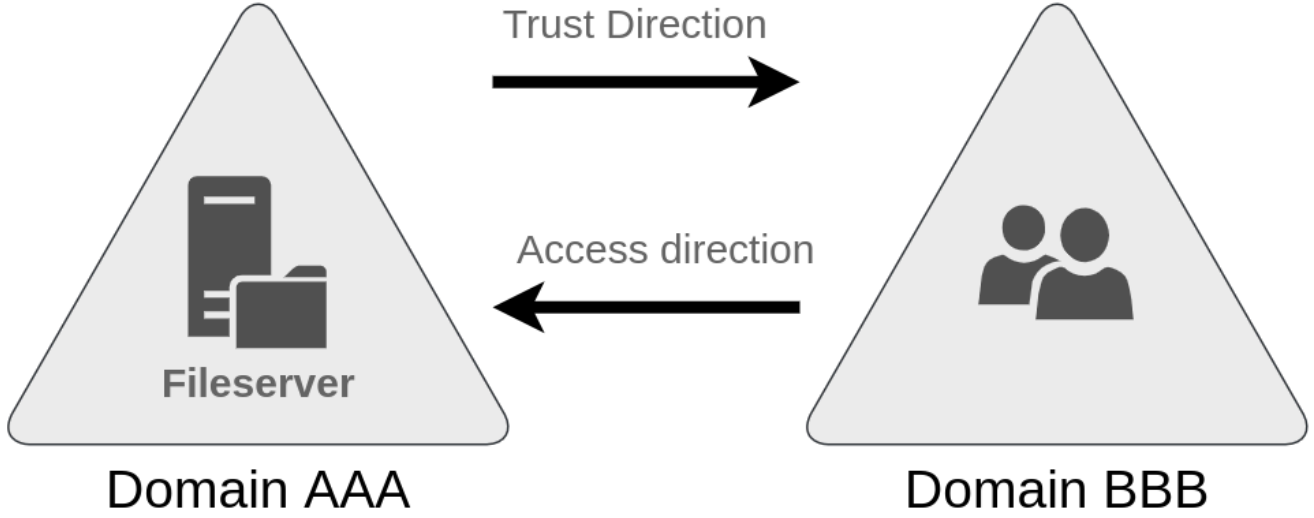
Domainleri ağaçlara ve ormanlara böldük, peki ya birbiriyle konuşmaları gerekirse? Örneğin, THM UK domainindeki bir kullanıcının, MHT ASIA domainindeki bir dosya sunucusuna erişmesi gerekiyorsa ne olacak?

İşte burada **Trust (Güven)** ilişkileri devreye girer. Trust, bir domainin diğer domaindeki kullanıcıları tanımasını (authorize) sağlar.

Trust Türleri

A. One-Way Trust (Tek Yönlü Güven)

Bu ilişki türü biraz kafa karıştırıcı olabilir, yönüne dikkat etmek gerekir.



- **Senaryo:** Domain AAA (Güvenen - Trusting), Domain BBB 'ye (Güvenilen - Trusted) güveniyor.
- **Sonuç:** Domain BBB içindeki kullanıcılar, Domain AAA içindeki kaynaklara (dosya, yazıcı) erişebilir.
- **Tersi:** AAA kullanıcıları BBB kaynaklarına erişemez.
- **Mantık:** "Ben sana güveniyorum, o yüzden senin kullanıcıların benim evime girebilir."

Akılda Tutma İpucu: Okun Yönü (Güven Yönü) ile Erişim Yönü (Access Direction) birbirine **Terstir**.

- Trust: A -> B (A, B'ye güvenir)
- Access: B -> A (B'deki kullanıcı A'ya girer)

B. Two-Way Trust (Çift Yönlü Güven)

Her iki domain de birbirine güvenir.

- THM kullanıcıları MHT kaynaklarına erişebilir.
- MHT kullanıcıları THM kaynaklarına erişebilir.
- **Varsayılan Davranış:** Bir Tree veya Forest içindeki domainler (örneğin `uk.thm.local` ve `us.thm.local`) varsayılan olarak **Two-Way Trust** ile birbirine bağlıdır.

Kritik Not

Güven ilişkisi kurmak, kapıları sonuna kadar açmak demek değildir. Trust sadece "**kimlik doğrulamaya**" izin verir.

- Trust kurduğunuzda, diğer domaindeki kullanıcılar otomatik olarak sizin sunucularınıza erişemez.

- Sadece **yetki verirsiniz** (Örn: MHT\Ali kullanıcısını THM\DosyaSunucusu erişim listesine eklerseniz) erişebilirler.